

ConcertDef-SBOM — IBM Bob Custom Mode

Automating Application SBOM generation & upload for IBM Concert

IBM Concert	Bob IDE	SBOM v1.0.2	MCP Server	Trivy / Snyk / Gripe
-------------	---------	-------------	------------	----------------------

WHAT IT IS

ConcertDef-SBOM is a custom mode for the **IBM Bob** AI coding assistant that turns vulnerability scan reports into schema-compliant **ConcertDef Application SBOMs (v1.0.2)** and uploads them — together with the underlying scan reports — directly to **IBM Concert**. It removes manual JSON-crafting, schema lookups, and API plumbing, letting users go from raw Trivy / Snyk / Gripe output to a fully registered application in Concert through natural-language prompts.

KEY CAPABILITIES

- Generate **ConcertDef SBOM v1.0.2** from scan reports
 - Parse **Trivy, Snyk, Gripe** & CycloneDX outputs
 - Auto-extract containers, code repos & libraries
 - Enforce schema, bom-ref & dependency validation
- Upload Application SBOM to IBM Concert
 - Upload **image / code / VM** vulnerability scans
 - Maintain component ↔ scan name consistency
 - Document the SBOM generation workflow

HOW IT WORKS

1. Discover	2. Extract	3. Generate	4. Validate	5. Upload
Locate Trivy / Snyk / Gripe scan reports in workspace	Pull components, versions, repos & image digests	Build ConcertDef v1.0.2 SBOM JSON via Bob	Check bom-refs, deps & required metadata	Push SBOM & scans to IBM Concert via MCP server

SETUP & EXAMPLE PROMPTS

SETUP (5 STEPS)

- Open Bob IDE → Settings → **Modes** → Global Modes
- Paste *ConcertDef-SBOM* entry from `custom_modes.yaml`
- Copy `rules-concertdef-sbom/` to `~/ .bob/`
- Configure & run the **Concert MCP server**
- Restart Bob IDE & pick the mode from the selector

EXAMPLE PROMPTS

- “Refer the Trivy reports in this directory and generate a ConcertDef SBOM for application robot-shop. Repo URL: <https://github.com/instana/robot-shop>”*
- “Upload robot-shop ConcertDef SBOM @/robot-shop-sbom.json to IBM Concert.”*
- “Upload all Trivy image scan reports in this directory to IBM Concert.”*

DEMO PACK & REPO COMPONENTS

DEMO PACK INCLUDED

- Sample app: **robot-shop** (Instana)
- 1 source-code Trivy scan + 5 image SBOMs
- Ready-to-run prompts in README

REPO COMPONENTS

- **custom_modes.yaml** — Bob mode definition
- **rules-concertdef-sbom/** — workflow, best-practices, examples, tool & MCP rules (5 XML rule files)
- **robot-shop-scan-reports/** — demo scan inputs

Why it matters	Cuts SBOM authoring from hours of hand-editing JSON to a single prompt; guarantees Concert-ready output and consistent component naming across SBOM and scans.
Built for	AppSec, DevSecOps & platform teams onboarding applications into IBM Concert; demo-ready for client & internal enablement sessions.